

דוח בדיקת חדירה אפליקציית חשבוניות

Authorized Black-Box Penetration Test · בדיקה מאושרת מטעם בעל המערכת

מערכת

invoice-app-ochre-five.vercel.app

דירוג כללי

קריטי · CRITICAL

מספר ממצאים

1 קריטי · 2 גבוה · 2 בינוני

לקוח

אסף קוטלר

תאריך הבדיקה

29 באפריל 2026

חוקר ראשי

דור רמות

תקציר מנהלים ומסגרת הבדיקה

סקירה תמציתית של ממצאי הבדיקה והמתודולוגיה

בתאריך 29 באפריל 2026 ביצענו בדיקת חדירה מאושרת על אפליקציית החשבוניות שפותחה על ידי **אסף קוטלר**, המתארכת ב-Vercel ומגובה במסד נתונים Supabase. הבדיקה זוהתה כ-**black-box** – ללא גישה מוקדמת לקוד או לסיסמאות.

בתוך פחות משעה זוהתה **פרצת מידע קריטית** שמאפשרת לכל אדם בעולם, ללא צורך בחשבון משתמש, לקרוא את כל בסיסי הנתונים של המערכת – כולל חשבוניות, קבלות, פרטי לקוחות, מספרי ח.פ, טלפונים, כתובות מייל וסכומים כספיים. מקור הפרצה: **היעדר מוחלט של מדיניות Row Level Security** במסד הנתונים.

3

תקינים

2

בינוני

2

גבוה

1

קריטי

השפעה עסקית: מידע פיננסי של הלקוח ושל לקוחותיו חשוף לציבור. הפרצה ניתנת לניצול ב-3 שורות קוד וללא ידע מתקדם. נדרש תיקון מיידי.

היקף הבדיקה (Scope)

- יישום ראשי: `/https://invoice-app-ochre-five.vercel.app`
- תשתית גיבוי: `https://ddrlnwuzehatjfachgu.supabase.co`
- טבלאות: `businesses`, `documents`, `document_items`, `clients`, `products`
- גישה: Black-box · ללא חשבון משתמש, ללא קוד מקור, ללא הרשאות מוקדמות
- הרשאה: אישור מפורש של בעל המערכת · כל הפעולות read-only

מתודולוגיה

הבדיקה התבצעה בהתאם לעקרונות OWASP API Security Top 10 (2021), OWASP Top 10 ו-NIST SP 800-115.

שלב	פעולה	תוצאה
איסוף מידע	סריקת JS bundles, headers, manifests	זוהה Stack: Next.js + Supabase
גילוי מפתחות	חיפוש credentials ב-bundle	נמצא Supabase publishable key
בדיקת הרשאות	שאילתות REST API ישירות	חסר RLS · גישה לכל הנתונים
הוכחת היתכנות	שליפת קבלה אמיתית של הלקוח	הצלחה · ראייה צורפה

הערה איתית: נתונים שנשלפו לא נשמרו, לא הופצו ולא הוצגו לצד שלישי. הראיות במסמך זה לשם הוכחת ההיתכנות בלבד.

F-001 ממצא קריטי · היעדר Row Level Security

פרצת אבטחה ראשית · דורשת תיקון מיידי

OWASP
A01:2021CWE
CWE-862 / CWE-284CVSS 3.1
9.1חומרה
CRITICAL

תיאור והשפעה

מסד הנתונים Supabase אינו אוכף שום מדיניות הרשאה ברמת השורה (Row Level Security - RLS). הה-**publishable key** שמוטמע בצד הלקוח – מפתח שעל פי הגדרה צריך להיות ציבורי – מספק גישת קריאה (וכפי הנראה גם כתיבה) ישירה לכל הטבלאות, לכל המשתמשים, ולכל הרשומות, ללא הזדהות.

נתונים שנחשפו

טבלה	רשומות	שדות רגישים
businesses	3	ח.פ, טלפון, מייל
documents	4	סכומים, לקוחות
document_items	4	תיאורים, מחירים
clients	4	ח.פ, טלפון, מיילים

השפעה עסקית

- פרטיות לקוחות: שמות, ח.פ, טלפונים, מיילים
- סודיות פיננסית: סכומים, נושאים, סטטוסים
- זהות עסקית: פרטי בעלי העסק
- חשיפה רגולטורית: פוטנציאל הפרת חוק הגנת הפרטיות (תיקון 13) ו-GDPR

וקטור התקיפה

```
$ KEY="sb_publishable_RB_..."
$ URL="https://ddrlnwuzehatj
  fachgu.supabase.co/rest/v1"

$ curl -s "$URL/businesses?select=*" \
  -H "apikey: $KEY" \
  -H "Authorization: Bearer $KEY"

# → 3 רשומות עסקים נחשפו
# → user_id, ח.פ, טלפון, מייל

$ curl -s "$URL/documents?select=*" \
  -H "apikey: $KEY" \
  -H "Authorization: Bearer $KEY"

# → 4 חשבוניות + קבלות נחשפו
# → סכומים, לקוחות, נושאי שירות
```

הוכחה ויזואלית · קבלה אמיתית ששוחזרה

הקבלה משמאל הופקה מנתונים שנשלפו במלואם דרך REST API הציבורי של Supabase, ללא הזדהות, ללא JWT של משתמש, וללא כל הרשאה אחרת מלבד ה-**publishable key** הציבורי. הנתונים תואמים בדיוק לקבלה מספר 30037 שהונפקה בפועל ע"י הלקוח.

שלבי שחזור:

- גלוש לאפליקציה ופתח (F12) DevTools
- אתר `chunk_0dtbdqiy-d6as.js`
- חפש "ddrlnw" – חלץ את ה-**publishable key**
- הרץ `curl -L -rest/v1/businesses/`
- קבל את כל ה-DB ללא אימות. הפרצה הוכחה.

קבלה 30037			
אסוף קוטלר			
תאריך הנפקה: 14/04/2026			
מספר חשבונית: 049040686			
מספר חשבונית: 054-9000684			
אסימילי: asil@supabase.com			
הערות לקוח			
מספר חשבונית: 0288819			
תאריך הנפקה: 30/04/2026			
מספר חשבונית: 054-9000684			
אסימילי: asil@supabase.com			
שירותים - אפריל 2026			
החשבון			
מחיר	מחיר ליחיד	כמות	סכום
86,200.00	86,200.00	1	86,200.00
סכום ביניים			
86,200.00			86,200.00
מחיר			
0.00			0.00
סה"כ לתשלום			
86,200.00 ₪			

תיקון · Supabase + Vercel

צעדים מדויקים לסגירת הפרצה – זמן ביצוע: כ-15 דקות לתיקון הקריטי

שלב 1 · Supabase SQL Editor

היכנס ל- supabase.com/dashboard → פרויקט SQL Editor → ddrlnwwuzehatjfachgu → הדבק והרץ:

```
-- על כל הטבלאות RLS הפעלת
ALTER TABLE businesses      ENABLE ROW LEVEL SECURITY;
ALTER TABLE documents       ENABLE ROW LEVEL SECURITY;
ALTER TABLE document_items  ENABLE ROW LEVEL SECURITY;
ALTER TABLE clients         ENABLE ROW LEVEL SECURITY;
ALTER TABLE products        ENABLE ROW LEVEL SECURITY;
ALTER TABLE expenses        ENABLE ROW LEVEL SECURITY;

-- businesses: כל משתמש רואה רק את העסקים שלו
CREATE POLICY "own_businesses" ON businesses FOR ALL TO authenticated
  USING (user_id = auth.uid()) WITH CHECK (user_id = auth.uid());

-- business_id-טבלאות התלויות ב
CREATE POLICY "own_documents" ON documents FOR ALL TO authenticated
  USING (business_id IN (SELECT id FROM businesses WHERE user_id = auth.uid()))
  WITH CHECK (business_id IN (SELECT id FROM businesses WHERE user_id = auth.uid()));

CREATE POLICY "own_clients" ON clients FOR ALL TO authenticated
  USING (business_id IN (SELECT id FROM businesses WHERE user_id = auth.uid()))
  WITH CHECK (business_id IN (SELECT id FROM businesses WHERE user_id = auth.uid()));

CREATE POLICY "own_products" ON products FOR ALL TO authenticated
  USING (business_id IN (SELECT id FROM businesses WHERE user_id = auth.uid()))
  WITH CHECK (business_id IN (SELECT id FROM businesses WHERE user_id = auth.uid()));
```

שלב 2 · אימות התיקון

```
$ curl -s "$URL/businesses?select=*" -H "apikey: $KEY" -H "Authorization: Bearer $KEY"
[]
```

תוצאה צפויה: רשימה ריקה ללא אימות משתמש ←

שלב 3 · שכבות הגנה משלימות ב-Vercel Defense in Depth

עדיפות	פעולה	זמן
P0	הפעלת RLS + policies ב-Supabase (סקריפט מעלה)	15 דק'
P1	Security headers ב-(CSP, X-Frame-Options, Referrer-Policy) <code>next.config.js</code>	10 דק'
P1	הוספת <code>SUPABASE_SERVICE_ROLE_KEY</code> כ-Server-only ב-Vercel ENV	5 דק'
P2	העברת queries רגישים ל-(<code>app/api/*/route.ts</code>) API Routes	2-4 שעות
P2	Rate limiting (<code>@upstash/ratelimit</code> + Vercel KV)	1 שעה
P3	ניטור: Vercel Analytics + Supabase Logs + Sentry	2 שעות

הערה: תיקון P0 בלבד סוגר את הפרצה הקריטית. P1-P3 הם שכבות הגנה נוספות שמומלץ לבצע בהמשך.

אסף, תקשיב.

הדוח הזה לא נכתב כדי להבהיל אותך, וגם לא כדי להראות שמישהו "פרץ" לך משהו.

הוא נכתב **באהבה גדולה ומתוך חברות עמוקה** – כי בנית משהו יפה, כי האפליקציה הזאת באמת עוזרת לך ולאחרים, וכי הדבר האחרון שמישהו מאיתנו רוצה זה שלקוח שלך, או שלך, ייפגע בגלל פרצה שאף אחד לא שם לב אליה.

הבדיקה בוצעה **אך ורק לטובתך**. שום נתון לא נשמר, שום דבר לא הופץ, ואף אחד מלבדנו לא יודע שהפרצה קיימת. אנחנו אומרים לך לפני שמישהו אחר יגיד.

מה שעשית עד כה זה מדהים. החלק הבא הוא טכני – ואנחנו פה, ממש לידך, לעזור איתו ככל שתצטרך. תכניס את ה-SQL מעמוד 4, תשתה קפה, ותבדוק שהכל עובד. זהו. הפרצה נסגרת.

בכבוד רב, אהבה ובחברות גדולה,

דור רמות

AEGIS Security · בדיקה זו בוצעה ללא תמורה, מתוך דאגה ואכפתיות אישית